

Identita v cloudovém prostředí aneb jak se zbavit hesel



Ondřej Šika

SikaLabs s.r.o.

ondrej@sika.io

@ondrejsika

/in/ondrejsika

Cloud Computing Conference,
Praha, 12. 5. 2026

Ondřej Šika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com

```
▼ .env
... @@ -1 +1,2 @@
1 1 REDIS=redis-example-260512.redis.cache.windows.net
2 + REDIS_PASSWORD=GJw7_Ac3I_UbJb_JD0L
```



Ondřej Šika

Jsem DevOps engineer, architekt,
konzultant a školitel z Prahy.

Navrhnou a implementuji Vám na míru
DevOps architekturu od verzování v
Gitu po provoz kontejneru v
Kubernetes v Cloudu.

A vše co umím Vás i naučím :)

+ mám skvělý team v SikaLabs

Ondřej Šika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Pomůžu Vám s DevOps, Kontejnery a Cloudem

Pomůžu Vám s konkrétním problémem v
DevOps, s kontajnery nebo s Kubernetes
formou školení a konzultacemi

Moje nejpopulárnější kurzy jsou:

- Kubernetes, OpenShift
- Docker, Gitlab CI
- ArgoCD, Terraform

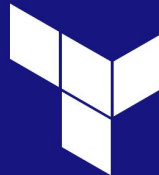
Více na sika.link/skoleni

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com

Kubernetes



Terraform



Docker



Prometheus



Rancher



ArgoCD



Gitlab CI



Git



Ansible



Elk



DigitalOcean



Proxmox



SikaLabs

Nedělám vše sám, mám **skvělé kolegy!**

Pomůžeme Vám s implementací a migrací do
Kubernetes nebo Cloudu.

Důvěřují nám startupy, banky i státní instituce.



Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com

Náš DevOps Stack

- Git, Gitlab - Versioning & Collaboration
- Gitlab CI, ArgoCD, Kargo - CI/CD
- Docker, Kubernetes, OpenShift - Containers & Orchestration
- RKE2 & SLKP - Kubernetes Provisioning
- Terraform - Infrastructure management
- Prometheus, Alertmanager, Grafana - Monitoring Stack
- Elastic Stack / Loki - Log Management
- Azure, AWS, DigitalOcean, VMWare, Proxmox - Public or Private Cloud



Identita v cloudovém prostředí aneb jak se zbavit hesel



Proč to řešíme?

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Commit 376cb29



ondrejsika committed 2 minutes ago Verified

feat(.env): Add REDIS_PASSWORD



main

1 parent [86bf754](#) commit 376cb29

1 file changed

+1



Search within code



▼ .env



...

@@ -1 +1,2 @@

1

1

REDIS=redis-example-260512.redis.cache.windows.net

2

+ REDIS_PASSWORD=GJw7_Ac3I_UbJb_JD0L

Hesla jsou nejslabší článek

- `.env` commitnutý do gitu
- Heslo poslané přes Teams / Slack “jen dočasně”
- Service account token, který nikdo nerotuje
- Credentials v poznámkovém bloku, sdíleném excelu



```
▼ .env ...  
... @@ -1 +1,2 @@  
1 1 REDIS=redis-example-260512.redis.cache.windows.net  
2 + REDIS_PASSWORD=GJw7_Ac3I_UbJb_JD0L
```



Long-lived credentials jsou problém

- Platí navždy a odkudkoliv
- Nevíš kdo a kdy klíč používal
- Rotace bolí – musíš najít všechna místa
- Problém s rušením přístupů (vyžadují rotaci)
- Leak = okamžitý problém, detekce = pozdní

=> Je to technický dluh



Příklady problémů

Jeden service principal, Contributor na celé subscription,
secret na 5 místech

Všichni uživatelé i aplikace používají stejné heslo do DB



Řešení?

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Identity based approach

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Identity Based Approach

- Každý přístup je svázaný s konkrétní identitou – uživatel, aplikace, služba
- Identita je ověřená platformou, ne heslem
- Přístup je omezený na minimum (least privilege)
- Každý přístup je auditovaný – kdo, co, kdy, odkud
- Identita má životní cyklus – vznik, použití, zánik



Identity Based Approach

Místo statických hesel a tokenů budeme používat identity

- Uživatelské identity
- Workload identity



Identita pro uživatele

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Identita pro uživatele

- Uživatel se přihlásí přes SSO (Entra ID, Keycloak, ...)
- MFA, Conditional Access
- Přístup k Azure portálu, CLI, serverům, aplikacím
- Onboarding a Offboarding na jednom místě (v SSO)

Žádné sdílené účty. Každý uživatel má vlastní identitu s vlastním audit logem.



Example: SSH with Entra



Role Assignment

```
88
89  ✓ resource "azurerm_role_assignment" "vm_admin_login" {
90      scope                = module.vm.id
91      role_definition_name = "Virtual Machine Administrator Login"
92      principal_id         = data.azurerm_client_config.current.object_id
93  }
94
```



az ssh



```
→ az ssh vm -g az-ssh-example -n az-ssh-example
```

On May 21st 2025, any ssh commands connecting to ARC machines on versions <2.0.4 will no longer work. Please upgrade to az ssh version >=2.0.4

```
Linux az-ssh-example 6.1.0-47-cloud-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.170-3 (2026-05-08)
x86_64
```

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

Last login: Mon May 11 23:43:32 2026 from 85.71.71.34

ondrej@sika.io@az-ssh-example:~\$

logout

Connection to 137.117.132.142 closed.

Transferred: sent 7248, received 6656 bytes, in 3.6 seconds

Bytes per second: sent 2008.7, received 1844.6

Identita pro workload

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Jak funguje Workload Identity

Identita přiřazená workloadu platformou – ne statické heslo uložené někde.

- Platforma ví, kde workload běží
- Workload dostane krátkodobý token
- Token vyprší sám – žádná rotace, žádný únik
- Platí pouze pro konkrétní workload

Žádné heslo nikde uložené.



Workload Identity na VM

- VM má přiřazenou Managed Identity
- Aplikace zavolá lokální IMDS endpoint (169.254.169.254)
- Azure vrátí krátkodobý access token
- Aplikace použije token pro přístup k Azure resource





JSON Claims Breakdown

Decoded Payload

JSON Claims Breakdown



Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com

Example: Redis with Identity



Redis with AAD

```
resource "azurerm_redis_cache" "example" {  
  name                = local.redis_name  
  location            = azurerm_resource_group.example.location  
  resource_group_name = azurerm_resource_group.example.name  
  capacity            = 0  
  family              = "C"  
  sku_name            = "Basic"  
  non_ssl_port_enabled = true  
  minimum_tls_version = "1.2"  
  redis_version        = 6  
  public_network_access_enabled = true  
  
  redis_configuration {  
    authentication_enabled           = true  
    active_directory_authentication_enabled = true  
  }  
}
```

Role Assignment

```
resource "azurerm_redis_cache_access_policy_assignment" "vm" {  
  name                = "vm-identity"  
  redis_cache_id      = azurerm_redis_cache.example.id  
  access_policy_name  = "Data Contributor"  
  object_id           = module.vm.principal_id  
  object_id_alias     = azurerm_redis_cache.example.name  
}
```



Redis creds z VM



```
default@identity-example-with-redis:~$ TOKEN=$(curl -sf 'http://169.254.169.254/metadata/identity/oauth2/token?api-version=2018-02-01&resource=https://redis.azure.com' -H 'Metadata: true' | jq -r '.access_token')
default@identity-example-with-redis:~$ OID=$(echo "$TOKEN" | cut -d'.' -f2 | base64 -d 2>/dev/null | jq -r '.oid')
default@identity-example-with-redis:~$ export REDISCLI_AUTH=$TOKEN
redis-cli -h "$REDIS" -p 6379 --user "$OID" ping -h "$REDIS" -p 6379 --user "$OID"
PONG
default@identity-example-with-redis:~$
exit
```



Redis creds z VM v Go

```
13  ▾ func main() {
14      cred, err := azidentity.NewManagedIdentityCredential(nil)
15      handleError(err)
16
17      // Get a token for the Azure Redis service
18  ▾  token, err := cred.GetToken(context.Background(), policy.TokenRequestOptions{
19      |      Scopes: []string{"https://redis.azure.com/.default"},
20      |  })
21      handleError(err)
22
23      // Get the OID claim from the token
24      claims := jwt.MapClaims{}
25      jwt.NewParser().ParseUnverified(token.Token, claims)
26      oid, ok := claims["oid"].(string)
27      handleOK(ok, fmt.Errorf("OID claim not found in token"))
28
29      fmt.Println("Token:", token.Token)
30      fmt.Println("OID:", oid)
31  }
```

Workload Identity v AKS

- AKS cluster má OIDC issuer endpoint
- Pod dostane krátkodobý JWT token (ServiceAccount token)
- Azure AD důvěřuje OIDC issuer clusteru
- Pod vymění JWT za Azure access token

=> aplikace přistoupí k Azure resource



Ukazka Identity v AKS

[illegible]



Decoded Payload



om

On Premise?

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Identita v on-premise

Výhody identit lze využívat i v on-premise prostředí, je to složitější na setup - v public cloudu je vše připraveno

V Kubernetes i OpenShiftu je workload identita nativně, stejné jako AKS

Pro správu hesel, tokenů a přístupů k databázím můžeme používat Hashicorp Vault



Shrnutí

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Problémy které tento přístup řeší

- Hesla v .env souborech a git repozitářích
- Sdílení credentials přes Slack, Teams, e-mail
- Long-lived secrets které nikdo nerotuje
- Nevíme kdo a kdy credentials použil
- Jeden secret používaný na více místech
- Ruční rotace



Co tento přístup NEŘEŠÍ

- Špatně nastavené RBAC role – identita bez hesla s Owner právem je stále problém
- Kompromitovaný workload – pokud útočník běží uvnitř Podu, má jeho identitu
- Supply chain útoky – škodlivý kód v kontejneru zneužije identitu legitimně
- Insider threat – legitimní uživatel se správnými právy, ale alespoň máme access log



**Heslo, ktoré neexistuje,
neleakne a nemusíte ho rotovať**



Commit cb883fa



ondrejsika committed 1 minute ago Verified

feat(.env): Remove REDIS_PASSWORD

Switch to workload identity, no more needed



main

1 parent [376cb29](#) commit cb883fa

1 file changed

-1



Search within code



▼ .env



...

@@ -1,2 +1 @@

1

1

REDIS=redis-example-260512.redis.cache.windows.net

2

-

REDIS_PASSWORD=GJw7_Ac3I_UbJb_JD0L

Examples

- VM + Redis on Azure (using Terraform)

<https://sika.link/github-azure-identity-redis>

- Example Go App

<https://sika.link/github-azure-identity-redis-go>

- VM with az ssh access

<https://sika.link/github-az-ssh>



Díky za pozornost

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Otázky

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com



Email

ondrej@sika.io

Twitter

@ondrejsika

LinkedIn

/in/ondrejsika

Slides

sika.link/slides

Ondrej Sika, SikaLabs ~ ondrej@sika.io ~ sika.io ~ sikalabs.com

